**Assignment 5 -** Maintaining Compliance and Driving Continuous Improvement

Apply a long-term compliance strategy by creating a monitoring process, updating documentation, and responding to evolving CMMC requirements.

**Instructions:**

You've reached the stage where your organization is CMMC certified—but staying compliant requires vigilance and continuous improvement. In this assignment, you'll simulate how to maintain compliance between audits, track security incidents, and stay aligned with future DoD updates.

Use the scenario and questions below to reflect on strategies for post-certification upkeep.

**Scenario:**

Your company has achieved CMMC Level 2 certification. Three months post-certification:

- A phishing incident occurred, but wasn't reported until days later.
- Some employees are still using outdated password practices.
- A DoD update was issued, adjusting guidance on logging retention.
- No review of SSP or POA&Ms has occurred since certification.
- Your vendor hasn't submitted their latest compliance self-attestation.

Questions for this assignment

**Tasks:**

1. How should you structure a continuous monitoring schedule?

2. What process will you use to track and report incidents?

3. How often should policies and plans (e.g., SSP, POA&M) be reviewed?

4. What triggers should prompt CMMC documentation updates?

5. How do you ensure vendors stay compliant post-certification?

**Solution by the Instructor:**

**Tasks:**

1. How should you structure a continuous monitoring schedule?

2. What process will you use to track and report incidents?

3. How often should policies and plans (e.g., SSP, POA&M) be reviewed?

4. What triggers should prompt CMMC documentation updates?

5. How do you ensure vendors stay compliant post-certification?

**Sample Solution:**

1. Set monthly checks for log reviews, quarterly policy audits, and annual CMMC control reviews.
2. Use an incident response log with timestamps, incident type, affected assets, and response taken.
3. Review all major CMMC documents quarterly or immediately after any incident or system change.
4. Triggers include vendor changes, control failures, new threats, or updated CMMC/DoD guidance.
5. Require vendors to submit updated compliance reports semi-annually and audit them annually.